0.1 Kết quả đạt được

Đồ án đã xây dựng một hệ thống hỗ trợ phát hiện và phân tích phần mềm độc hại trên nền tảng Windows, kết hợp phân tích tĩnh bằng học máy với phân tích động trong môi trường sandbox. Hệ thống vận hành tự động từ khâu nhận tệp PE đầu vào đến khâu xuất báo cáo, không yêu cầu can thiệp thủ công, đáp ứng các yêu cầu chức năng và phi chức năng đặt ra tại Chương **??**.

Giai đoạn tĩnh so sánh ba thuật toán Random Forest, XGBoost và LightGBM trên cùng tập dữ liệu; LightGBM đạt AUC-ROC cao nhất là 0,9993 và được chọn triển khai. Kỹ thuật lựa chọn đặc trưng theo Importance Gain giảm số chiều từ 2.381 xuống 384 mà vẫn giữ F1 ở mức 0,9615 trên tập EMBER 2024. Ngưỡng phân loại được đặt ở 0,33 theo định hướng ưu tiên giảm bỏ sót mã độc.

Giai đoạn động thu thập sự kiện từ Sysmon và SilkETW, sau đó chuẩn hóa, dựng cây tiến trình, xây dựng chuỗi hành vi, trích xuất chỉ số xâm phạm và ánh xạ sang khung MITRE ATT&CK. Trên 100 mẫu mã độc thuộc bảy nhóm hành vi, 74% mẫu sinh bằng chứng hành vi cụ thể và hệ thống nhận diện đúng 99 mẫu. Kết quả của cả hai giai đoạn được tổng hợp thành một báo cáo JSON thống nhất và hiển thị qua giao diện web.

0.2 Hạn chế

Quy mô đánh giá động giới hạn ở 128 mẫu do chi phí thực thi trong sandbox, nên kết quả mang tính minh chứng hơn là thống kê trên tập lớn. Khoảng 17% mẫu mã độc không bộc lộ hành vi trong cửa sổ quan sát do sử dụng kỹ thuật né tránh môi trường ảo hóa, vốn nằm ngoài phạm vi xử lý của đồ án.

Giai đoạn tĩnh vẫn sinh báo động giả trên một số phần mềm hợp pháp được đóng gói nặng, do cấu trúc tệp gần với mã độc. Cơ chế kết hợp kết quả hai giai đoạn dựa trên tập quy tắc cố định, chưa học tự động từ dữ liệu nên còn trường hợp quy tắc tiêm mã kích hoạt sai. Phạm vi đồ án cũng giới hạn ở tệp PE trên Windows, chưa bao gồm tài liệu chứa macro hay tệp kịch bản.

0.3 Hướng phát triển

Hướng phát triển trước mắt là nâng cao khả năng quan sát đối với mẫu né tránh sandbox, thông qua giả lập tương tác người dùng, kéo dài thời gian quan sát và che giấu dấu hiệu môi trường ảo hóa. Cơ chế tổng hợp kết quả có thể được thay bằng một mô hình học máy kết hợp đặc trưng tĩnh và động, giảm phụ thuộc vào tập quy tắc thủ công.

Về dữ liệu, quy mô đánh giá động có thể mở rộng bằng cách tự động hóa việc thực thi song song trên nhiều máy ảo. Về phạm vi, hệ thống có thể được mở rộng

để phân tích thêm tài liệu Office chứa macro và tệp kịch bản, đồng thời bổ sung phân tích bộ nhớ và lưu lượng mạng nhằm làm giàu bằng chứng hành vi.